

Project Report
On
PROMPTHOUND
Static Risk Analysis Tool
for AI Agent Skill Files



Submitted
In partial fulfilment
For the award of the Degree of

AI For Cybersecurity
(Collaboration with Intel)

C-DAC (Mohali)

Submitted By:

BARINDERPREET SINGH
MEHAKDEEP KAUR
TUSHAR KUMAR
INDERPREET SINGH

PROMPTHOUND

Static Risk Analysis Tool for AI Agent Skill Files

ABSTRACT

Artificial Intelligence (AI) is transforming software development by enabling autonomous AI agents capable of performing complex tasks such as code generation, testing, debugging, documentation, and workflow automation. These AI agents rely on **Skill Files**, which define the capabilities, permissions, and instructions that guide their behavior. While this significantly improves productivity, it also introduces serious cybersecurity challenges. Malicious or poorly designed skill files can contain hidden commands, credential exposure, obfuscated payloads, and unauthorized capabilities that may compromise an entire system once executed.

PromptHound is developed as an **offline static risk analysis tool** for AI Agent Skill Files. Instead of executing the skill file, the system performs static analysis to identify potential security threats before deployment. The tool combines heuristic analysis with machine learning techniques to detect dangerous interpreter calls, shell execution commands, Base64 obfuscation, credential leakage, and capability mismatches. By identifying these threats at an early stage, PromptHound helps developers and organizations prevent security breaches while maintaining developer productivity.

Unlike many existing AI security solutions that depend on cloud services or Large Language Models, PromptHound performs deterministic offline analysis, ensuring privacy and making it suitable for enterprise as well as air-gapped environments. The project also supports integration into CI/CD pipelines, allowing automated security checks before deployment. Overall, PromptHound contributes towards building trustworthy AI ecosystems by improving the security of AI agent skills.

INTRODUCTION

Artificial Intelligence has become one of the fastest-growing technologies across every industry. Organizations now use AI-powered assistants and autonomous agents to automate software development, customer support, document processing, testing, research, and decision-making. These intelligent systems improve efficiency by performing repetitive tasks with minimal human intervention.

Modern AI agents differ significantly from traditional chatbots. Instead of simply answering user queries, AI agents execute multiple actions autonomously using **Skill Files**. A skill file is a configuration document that specifies the tools, permissions, commands, and workflows available to the AI agent. For example, a coding assistant may use a skill file to define permissions for reading source code, executing terminal commands, accessing Git repositories, or installing software packages.

As organizations increasingly rely on AI agents, the security of these skill files becomes critically important. A malicious skill file may contain dangerous shell commands, hidden payloads, encoded malware, or exposed credentials that can compromise the entire development environment. Since developers frequently download AI skills from public repositories such as GitHub, there is a growing risk of unknowingly introducing malicious functionality into enterprise systems.

Existing AI platforms primarily focus on improving the capabilities of AI models but pay comparatively less attention to verifying the security of AI agent skill files before execution. This creates a major gap in enterprise AI security. PromptHound addresses this challenge by providing an intelligent offline security scanner capable of analyzing AI skill files before they are executed.

The system performs comprehensive static analysis using heuristic rules and machine learning techniques. It identifies suspicious behavior such as interpreter execution, shell command invocation, credential exposure, obfuscation techniques, and capability mismatches. Rather than blocking execution automatically, PromptHound generates detailed security reports that help developers make informed decisions regarding the safety of AI skills.

PROBLEM STATEMENT

The rapid adoption of Agentic AI has introduced new cybersecurity challenges that traditional security tools are not designed to address. AI agents often depend on third-party skill files downloaded from open-source repositories or shared among development teams. While these skill files improve functionality, they also create opportunities for attackers to embed malicious logic into AI systems.

A malicious skill file may include hidden shell commands, dangerous interpreter functions such as `eval()` or `exec()`, Base64-encoded payloads, hardcoded API keys, passwords, or unauthorized system capabilities. Since AI agents execute these instructions automatically, even a single malicious skill file can result in unauthorized system access, data leakage, privilege escalation, or malware execution.

For example, consider a software development company that uses AI coding assistants to automate debugging and testing. A developer downloads a third-party AI skill from GitHub to improve productivity. Unknown to the developer, the skill file contains an encoded shell command that downloads and executes malware. Without any security validation, the AI agent executes the malicious instruction, compromising the organization's internal network.

Traditional antivirus software focuses on executable files and malware signatures, while static code analyzers primarily inspect source code. However, they generally do not analyze AI agent skill files or evaluate AI-specific security risks such as capability mismatches or prompt-driven command execution.

Therefore, organizations require a dedicated security solution capable of performing offline static analysis of AI skill files before deployment. Such a solution should detect suspicious behavior, minimize false positives, provide explainable results, and integrate seamlessly into modern DevSecOps workflows. PromptHound has been developed specifically to address these challenges.

RESEARCH GAP

Although significant research has been conducted in Artificial Intelligence, Prompt Engineering, and Large Language Models, comparatively little attention has been given to the security of AI Agent Skill Files. Most existing studies focus on improving AI performance, optimizing prompt design, or defending against prompt injection attacks. Very few solutions specifically analyze the configuration files that control autonomous AI agents.

Existing security scanners also have several limitations. Many rely on cloud-based analysis, requiring organizations to upload sensitive files to external servers. This creates privacy concerns, especially for government organizations, financial institutions, and enterprises operating in air-gapped environments. Other solutions depend heavily on Large Language Models, making their outputs non-deterministic and difficult to reproduce consistently.

Furthermore, conventional static analysis tools are designed for programming languages such as C++, Java, or Python rather than AI skill files. As a result, they cannot accurately identify AI-specific risks such as capability mismatches, dangerous workflow definitions, or malicious prompt instructions embedded within skill configurations.

Another major challenge is the generation of false positives. Security tools that incorrectly classify safe files as malicious reduce developer trust and productivity. Organizations therefore require a balanced solution capable of achieving high detection accuracy while minimizing unnecessary alerts.

PromptHound addresses these research gaps by introducing a lightweight offline framework that combines heuristic analysis with a machine learning classifier. The system performs deterministic static analysis, protects user privacy, integrates with CI/CD pipelines, and provides explainable security reports suitable for enterprise environments.

OBJECTIVES

The primary objective of PromptHound is to improve the security of AI Agent ecosystems by identifying malicious or suspicious AI skill files before they are executed. As organizations increasingly depend on autonomous AI agents, ensuring the security of skill files becomes essential. PromptHound is designed to act as a proactive security layer that protects developers and enterprises from hidden threats while maintaining productivity.

The major objectives of the project are discussed below.

1. Detect Malicious AI Skill Files

The first objective is to identify AI skill files containing suspicious or malicious instructions. PromptHound scans every skill file using heuristic analysis and machine learning to determine whether it contains potentially dangerous behavior.

2. Detect Dangerous Commands

The project identifies dangerous interpreter functions such as `eval()`, `exec()`, shell commands, PowerShell commands, and subprocess execution that could allow attackers to execute arbitrary code on a system.

3. Prevent Credential Exposure

PromptHound detects hardcoded credentials such as passwords, API keys, AWS secrets, GitHub tokens, database connection strings, and authentication tokens that may accidentally be included inside AI skill files.

4. Detect Obfuscated Payloads

Attackers often hide malicious code using Base64 encoding or similar obfuscation techniques. PromptHound identifies such encoded content before execution.

5. Reduce False Positives

Many security tools classify safe files as malicious, reducing developer trust. PromptHound aims to achieve high detection accuracy while minimizing false alarms through machine learning.

6. Support Secure AI Adoption

The system enables organizations to adopt AI agents safely by integrating security checks into their development workflow.

7. Support DevSecOps

PromptHound can be integrated into GitHub workflows and CI/CD pipelines to automatically analyze AI skill files before deployment.

SCOPE OF THE PROJECT

The scope of PromptHound extends beyond individual developers and targets organizations adopting AI-driven software development and automation. As Agentic AI continues to evolve, AI skill security becomes an important component of enterprise cybersecurity.

The project can be applied across various domains.

Software Development Companies

Software companies frequently use AI coding assistants to automate debugging, documentation, testing, and code generation. Developers often install third-party AI skills downloaded from public repositories.

PromptHound analyzes these skills before execution, preventing malicious scripts from entering development environments.

Enterprise AI Platforms

Large organizations build internal AI assistants for business automation.

Examples include:

- Document processing
- Knowledge management
- Employee support
- Workflow automation

PromptHound verifies AI skills before deployment, reducing operational risk.

DevSecOps Teams

DevSecOps focuses on integrating security into software development.

PromptHound supports automated security scanning inside CI/CD pipelines, allowing organizations to identify unsafe AI skills before software deployment.

Government Organizations

Government agencies process confidential citizen information.

Because PromptHound performs **offline scanning**, no sensitive information leaves the organization, making it suitable for secure environments.

Banking Sector

Banks increasingly deploy AI assistants for fraud detection, customer support, and financial analysis.

PromptHound helps ensure AI skills cannot execute unauthorized commands or expose financial information.

Healthcare

Hospitals and healthcare providers use AI for clinical documentation, scheduling, and patient support.

PromptHound helps prevent malicious AI skills from accessing confidential patient records.

Research Organizations

Research institutions frequently experiment with new AI agents and open-source AI skills.

PromptHound verifies downloaded skills before they become part of research projects.

Open Source Communities

Thousands of AI skills are shared publicly.

PromptHound assists maintainers in reviewing community-contributed skills before acceptance.

LITERATURE REVIEW

Artificial Intelligence security has become an emerging research area due to the increasing adoption of Large Language Models and autonomous AI agents. Researchers have extensively studied prompt engineering, adversarial prompts, and prompt injection attacks. However, relatively little attention has been given to securing AI Agent Skill Files.

Traditional static analysis tools focus primarily on programming languages and executable files rather than AI configuration files. Although these tools successfully identify coding vulnerabilities, they cannot effectively detect capability mismatches or suspicious instructions specific to AI agents.

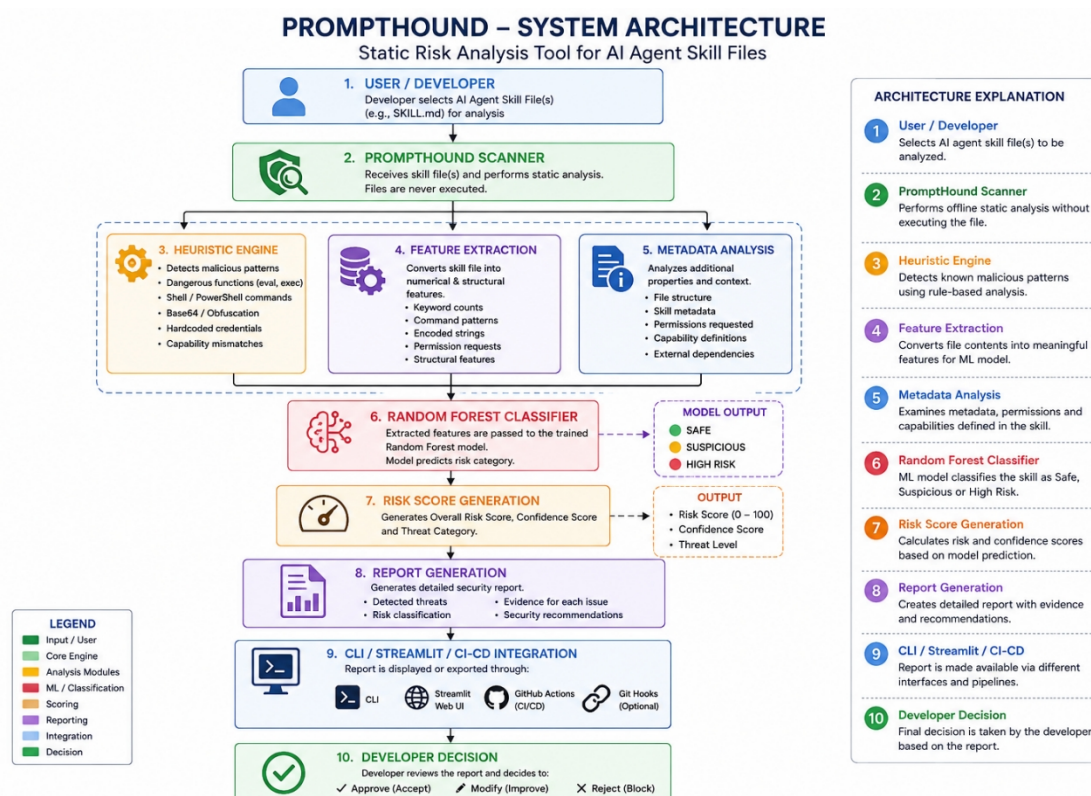
Several organizations have proposed AI security frameworks such as the **OWASP Top 10 for Large Language Model Applications**, which highlights risks including prompt injection, insecure output handling, excessive agency, and sensitive information disclosure. These frameworks provide general security guidance but do not specifically analyze AI skill files.

Recent research has also explored machine learning approaches for malware detection using feature extraction and ensemble learning algorithms such as Random Forest. These approaches have demonstrated strong performance in identifying malicious patterns while reducing false positives.

PromptHound combines concepts from static analysis, heuristic detection, and machine learning to create an explainable offline security scanner specifically designed for AI agent skill files. This combination fills an important research gap in the emerging field of Agentic AI security.

SYSTEM ARCHITECTURE

The architecture of PromptHound is designed to perform static analysis without executing the AI skill file. This approach improves security while maintaining user privacy.



1. The user provides an AI skill file.
2. PromptHound reads the file without executing it.
3. The heuristic engine searches for dangerous commands and suspicious patterns.
4. Features are extracted for machine learning analysis.
5. The Random Forest classifier predicts the risk level.

6. A detailed report is generated showing evidence and risk score.
 7. The developer or CI/CD pipeline decides whether the skill should be accepted or rejected.
-

METHODOLOGY / WORKFLOW

PromptHound follows a structured workflow to ensure accurate detection while avoiding unnecessary false alarms.

Step 1 - Skill File Collection

The user selects one or multiple AI skill files that need security analysis.

Step 2 - Static Analysis

Unlike dynamic analysis, the file is **never executed**. PromptHound only analyzes its contents, making the process safe.

Step 3 - Feature Extraction

Important security features are extracted, including:

- Dangerous interpreter calls
- Shell commands
- Base64 encoded content
- Credentials
- Capability definitions
- Structural metadata

Step 4 - Heuristic Analysis

The heuristic engine compares extracted features against predefined security rules to identify suspicious behavior.

Step 5 - Machine Learning Classification

The extracted features are passed to the trained **Random Forest classifier**, which predicts whether the skill file is Safe, Suspicious, or High Risk.

Step 6 - Risk Score Generation

The system calculates an overall risk score based on heuristic findings and machine learning predictions.

Step 7 - Report Generation

Finally, PromptHound generates a detailed report describing:

- Detected threats
- Risk category
- Evidence supporting the prediction
- Security recommendations

This workflow ensures AI skill files are analyzed safely and efficiently before deployment.
